# Repository and pipeline controls

Auditors care less about what the tests do than about whether anyone could have changed the tests, the results or the evidence without it being noticed. These are the settings that answer that. Most are switches in GitHub (or your client's equivalent), not code. The code already supports them: `CODEOWNERS`, the pull request template, the manifest and the checksums.

Treat this as a checklist and tick what applies to your client. Settings named below are in the repository's **Settings** page unless stated.

## 1. Protect the main branch

Settings, Branches, add a rule for `main`:

- [ ] Require a pull request before merging.
- [ ] Require at least one approval, and dismiss approvals when new commits are pushed.
- [ ] Require review from Code Owners. `.github/CODEOWNERS` lists the paths that define "validated": the requirement list, the pipeline, the tools and the infrastructure files. Replace the placeholder owner with the real reviewers.
- [ ] Require status checks to pass: the **Lint, typecheck, format** job and **E2E (chromium)**.
- [ ] Require signed commits, so each change is attributable to a verified person.
- [ ] Block force pushes and deletion of the branch.
- [ ] Include administrators, so the rules apply to everyone.

## 2. Attributable, protected identities

- [ ] Require two-factor authentication for everyone with access.
- [ ] Give people the least access they need. Separate who can approve from who can write tests if your quality system requires it.
- [ ] Turn on secret scanning and push protection.

## 3. Secrets

- [ ] Credentials live only in repository or environment secrets. Never in the code, the logs or the reports.
- [ ] Use a separate GitHub **Environment** for each target system, with its own secrets.
- [ ] For a production-like or validated environment, add **required reviewers** to its Environment, so a run against it waits for a named person to approve.

## 4. Evidence retention

When you start the workflow by hand with **regulated pack** ticked, the pipeline uploads an `evidence-<browser>` artifact with the traceability matrix, raw results, manifest and checksums. Everyday runs do not build it.

- [ ] Set the repository variable `EVIDENCE_RETENTION_DAYS` to the retention you can get. GitHub limits artifact retention by plan, so check what yours allows.
- [ ] For anything that must be kept longer, copy the approved evidence pack out of CI after sign-off, into the client's document system or immutable storage (for example object storage with a retention lock). CI artifacts are working copies, not the record.
- [ ] Record where the approved pack is stored in the summary report.

## 5. Keep the toolchain controlled

- [ ] Commit the lock file and use `npm ci`, so the same dependency versions are installed every time. The manifest records the lock file's hash.
- [ ] Keep the application images pinned by digest.
- [ ] Review Dependabot pull requests before merging. Playwright is excluded on purpose, because its version, the runner image and the visual baselines must change together.
- [ ] Record a toolchain change in the validation plan's change-control section, and re-run the suite.

## 6. Audit trail

Everything above leaves a record in the repository itself: pull requests with reviews, signed commits, the Actions run history and the evidence pack. For an audit, point to those rather than to anything made by hand.

## 7. Environments for dry and formal runs

If you use the regulated-run workflow (see dry-run-and-formal-run.md):

- [ ] Create two environments (Settings, Environments): `dry-validation` with no rules, and `formal-validation`.
- [ ] On `formal-validation`, add **Required reviewers**, so a named person approves every formal run before it starts. Tick "Prevent self-review" if the person who starts a run must not approve it.
- [ ] Restrict formal runs to release tags: that is what `formalRun.allowedRefs` in `config/regulated.json` checks. Protect the tags too (Settings, Rules, Rulesets), so a release tag cannot be moved or deleted.
- [ ] Leave `config/` under `CODEOWNERS`, so switching regulated mode on or off needs a code-owner review.

## What this does not cover

These settings reduce the chance of undetected change. They don't replace the client's quality management system, electronic-signature requirements or records policy. For rules such as 21 CFR Part 11 or EU Annex 11, decide with the client's quality team which of the records here are the "official" ones and where the signatures live.